INFORME DE PRUEBAS DE PENETRACIÓN

ABYSS

Evaluación de seguridad ofensiva · Laboratorio whoami-labs

Objetivo: 172.17.0.2 · Debian GNU/Linux

Dificultad: Media (3 puntos)

Fecha de la prueba: 10 de noviembre de 2026

Duración: 55 min 45 s

Resultado: Compromiso total del host (acceso root)

FLAG DE ROOT OBTENIDA

`ABYSS{d33p_s3cr3ts_r3v3al3d_99}`

Autor

Josep Sanz

Analista de seguridad ofensiva

CONFIDENCIAL

1. Resumen ejecutivo

Se realizó una prueba de penetración de caja negra contra la máquina **ABYSS** (172.17.0.2) del laboratorio whoami-labs, partiendo únicamente de conectividad de red. En menos de una hora se logró el **compromiso total del sistema**, obteniendo privilegios de `root` y la flag objetivo.

> La cadena de ataque encadena una **mala configuración crítica** (Redis sin autenticación que filtra credenciales en claro) con **secretos mal protegidos** (una clave privada SSH dentro de un ZIP con contraseña trivial) y una **regla sudo excesiva** (`NOPASSWD` sobre `find`). Cada eslabón es sencillo, pero juntos conducen de un acceso anónimo a control absoluto del host.

Se identificaron **cinco hallazgos**: uno de severidad crítica, dos altos, uno medio y uno bajo. El riesgo global es **alto**: la combinación permite pasar de cero a `root` sin explotar ninguna vulnerabilidad de software compleja, solo aprovechando configuraciones deficientes.

1	2	1	1
CRÍTICA	ALTAS	MEDIA	BAJA

Resumen de hallazgos

ID	Hallazgo	Severidad	CVSS	CWE
V-01	Redis expuesto en red sin autenticación y credenciales en texto claro	Crítica	9.8	CWE-306 · CWE-312
V-02	Clave privada SSH protegida con contraseña débil y ubicada en zona accesible	Alta	8.1	CWE-522 · CWE-326 · CWE-521
V-03	Escalada de privilegios: sudo NOPASSWD sobre / usr/bin/find	Alta	7.8	CWE-250 · CWE-269
V-04	Divulgación de información por ficheros de desarrollo y listado de directorios	Media	5.3	CWE-200 · CWE-548
V-05	Transporte sin cifrar y divulgación de versiones de servicio	Baja	3.7	CWE-319 · CWE-200

2. Alcance y autorización

Todas las pruebas se realizaron **exclusivamente** contra el laboratorio de prácticas autorizado, en un entorno aislado del que se dispone de permiso explícito de ataque. No se atacó ningún sistema de terceros. No se emplearon ataques de denegación de servicio.

Objetivo	ABYSS — 172.17.0.2 (whoami-labs)
Tipo de prueba	Caja negra (sin credenciales ni información previa)
Perímetro	Única IP 172.17.0.2 y sus servicios de red
Metodología	PTES / OWASP · técnicas mapeadas a MITRE ATT&CK
Fecha y hora	2026-11-10, finalización 16:24:41 (+0100)

Herramientas	Nmap, feroxbuster, Hydra, redis-cli, John the Ripper, OpenSSH, utilidades del sistema

3. Metodología y cadena de ataque

La evaluación siguió las fases habituales de una operación ofensiva. El flujo de extremo a extremo fue:

- **Reconocimiento** → descubrimiento de puertos y servicios con Nmap.
- **Enumeración web** → `feroxbuster`; fuga del usuario `scuba` en `/dev/changelog.txt`.
- **Acceso a credenciales** → Redis sin autenticación revela `scuba:underwater123!`.
- **Acceso inicial** → SSH como `scuba`.
- **Botín y cracking** → `captain_key.zip` → John the Ripper → contraseña `ocean` → clave `id_rsa`.
- **Movimiento lateral** → SSH como `captain` con la clave privada.
- **Escalada de privilegios** → `sudo find` (GTFOBins) → `root`.

Fase 1 · Reconocimiento

El escaneo de puertos revela tres servicios: SSH (OpenSSH 8.4p1), un servidor web Apache 2.4.67 y, de forma llamativa, una instancia de **Redis 6.0.16** expuesta en el puerto 6379/tcp.



Figura 1. Escaneo de puertos con Nmap sobre 172.17.0.2: SSH (22), HTTP/Apache (80) y Redis 6.0.16 (6379).

Fase 2 · Enumeración web y fuga de información

El fuzzing de rutas descubre el directorio `/dev/` con el listado de contenidos habilitado y el fichero `changelog.txt`, que incluye una nota del administrador revelando un usuario válido: `scuba`.



Figura 2. feroxbuster descubre el directorio /dev/ (con listado activado) y el fichero /dev/changelog.txt.

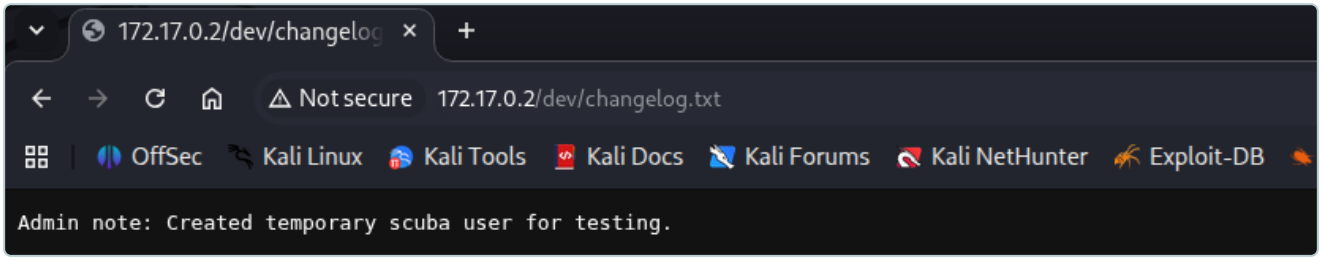


Figura 3. El changelog.txt filtra una nota del administrador que revela el usuario «scuba».

Fase 3 · Redis sin autenticación → credenciales

Se confirma que Redis no requiere contraseña. Mediante `redis-cli` se enumeran las claves y se recupera la credencial almacenada en texto claro: `user:scuba:password = underwater123!`.

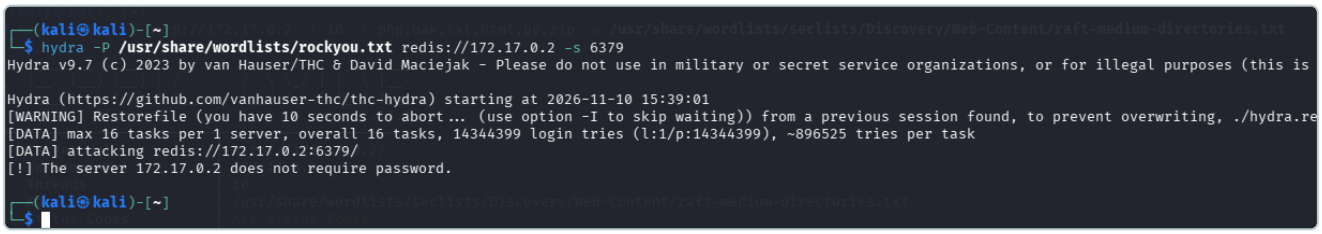


Figura 4. Hydra confirma que el servicio Redis no exige contraseña para autenticarse.

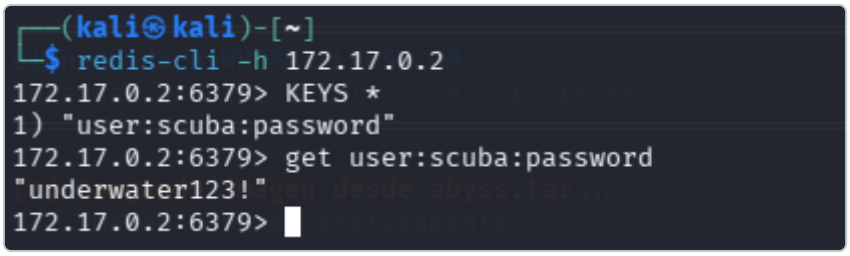


Figura 5. redis-cli: la clave user:scuba:password almacena la credencial en texto claro «underwater123!».

Fase 4 · Acceso inicial (SSH como scuba)

Con las credenciales obtenidas se accede por SSH como `scuba`. En su directorio personal se localiza `captain_key.zip`, un archivo protegido por contraseña. `scuba` no dispone de permisos `sudo`, por lo que la vía de escalada pasa por otro usuario.

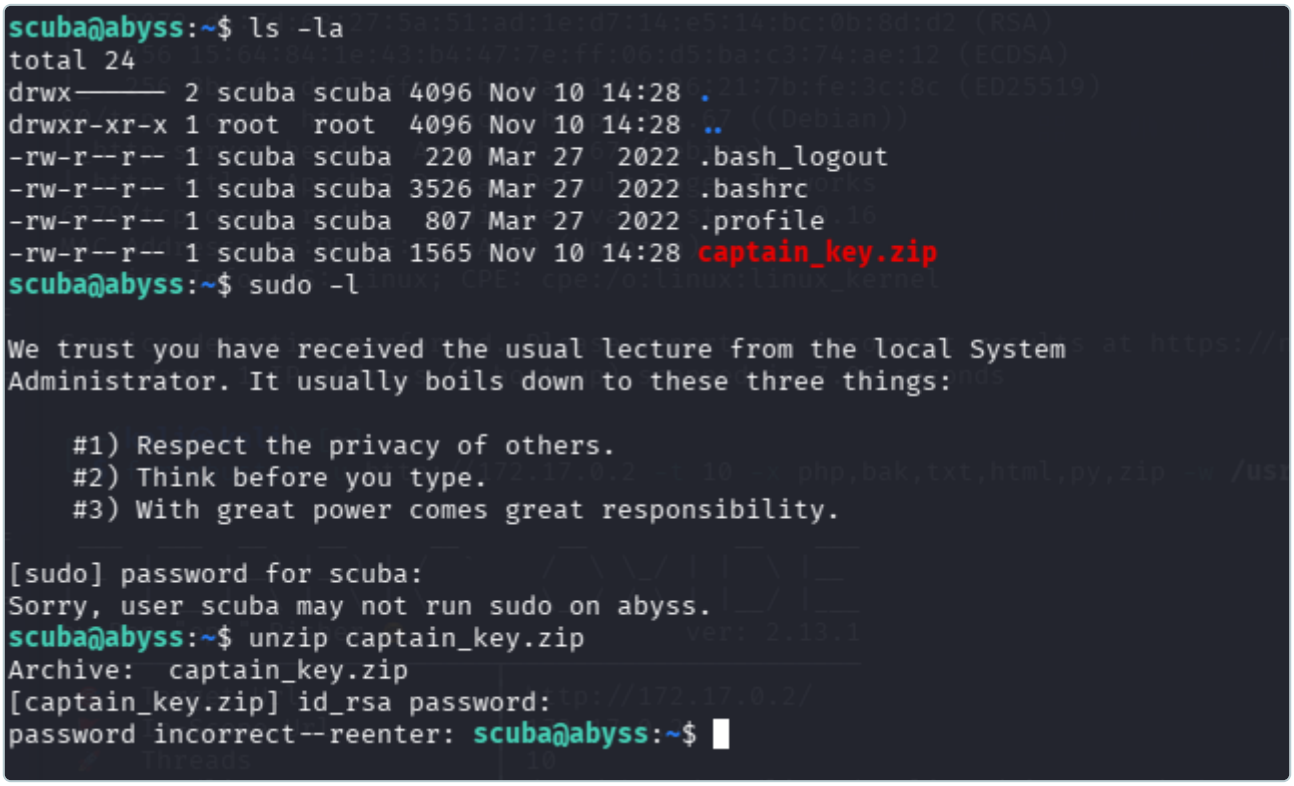


Figura 6. Acceso SSH como scuba. En su home aparece captain_key.zip (protegido). scuba no tiene permisos sudo.

Fase 5 · Botín y cracking offline

El ZIP contiene la clave privada SSH (`id_rsa`) del usuario `captain`. Se exfiltra con `scp` y se rompe offline con `zip2john` + John the Ripper usando `rockyou.txt`: la contraseña es `ocean`. Con ella se extrae la clave privada.

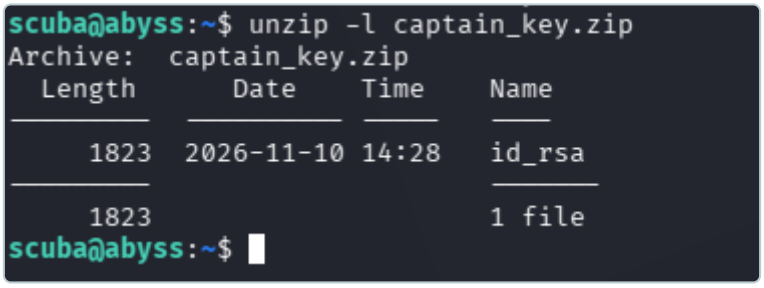


Figura 7. El contenido del ZIP es una clave privada SSH (id_rsa) del usuario captain.



Figura 8. El ZIP se exfiltra con scp y se rompe offline con zip2john + John the Ripper (rockyou): contraseña «ocean».

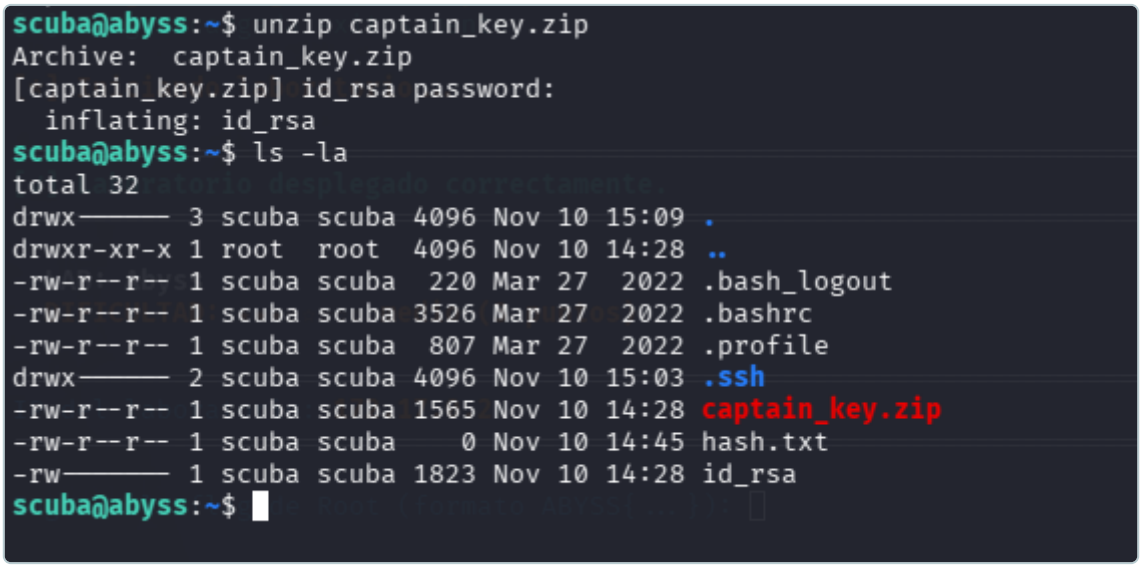


Figura 9. Descompresión del ZIP con la contraseña recuperada: se extrae la clave id_rsa.

Fase 6 · Movimiento lateral (captain)

Tras ajustar los permisos de la clave (`chmod 600`), se inicia sesión por SSH como `captain`. La enumeración de `sudo -l` muestra una regla peligrosa: `(ALL) NOPASSWD: /usr/bin/find`.

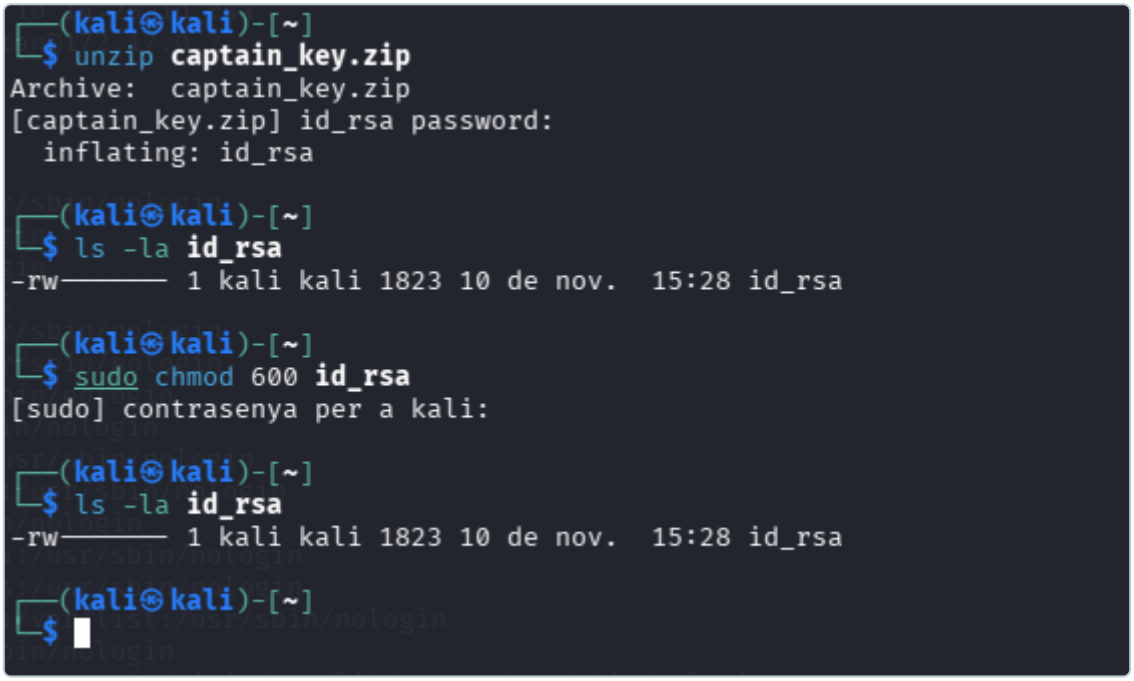


Figura 10. Preparación de la clave privada en la máquina atacante (permisos 600).

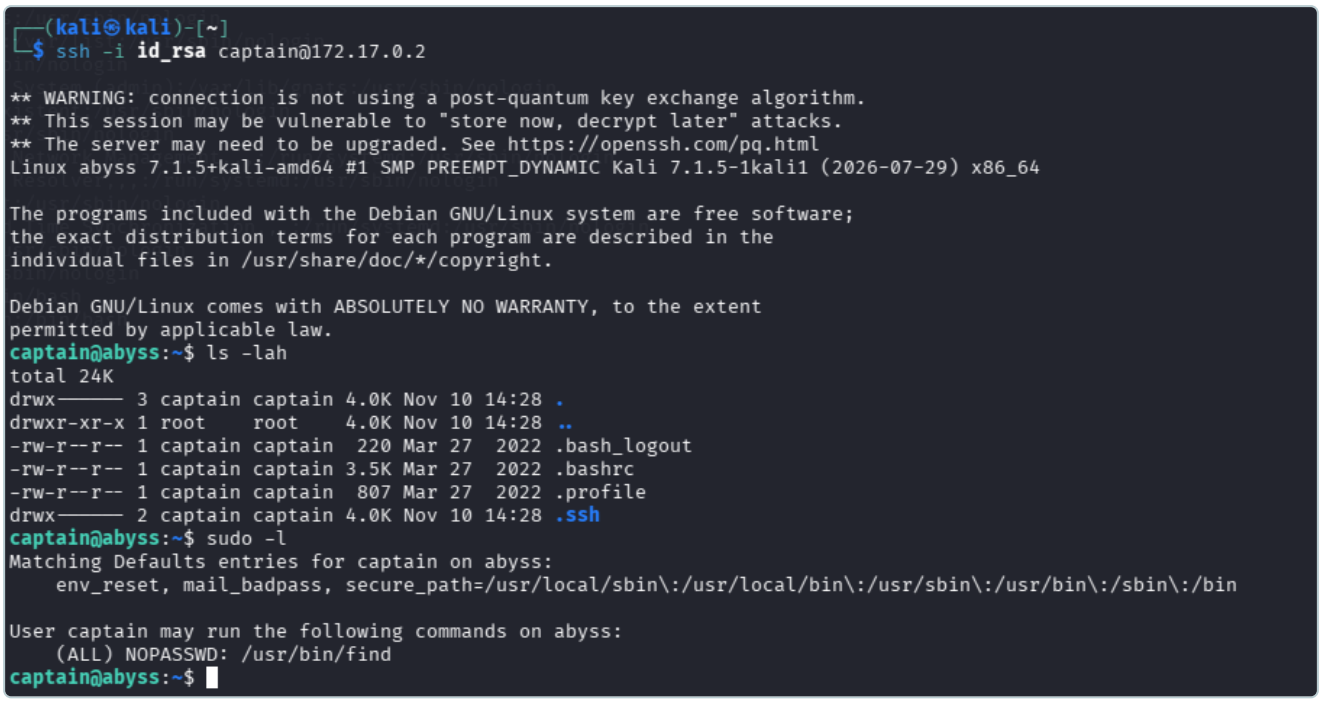


Figura 11. SSH como captain con la clave. sudo -l muestra: (ALL) NOPASSWD: /usr/bin/find.

Fase 7 · Escalada a root y captura de la flag

`find` permite ejecutar comandos con `-exec`. Al correr como root sin contraseña, `sudo /usr/bin/find . -exec /bin/bash -p \; -quit` devuelve una shell con `uid=0(root)`, desde la que se lee la flag en `/root/flag.txt`.

```
captain@abyss:~$ sudo /usr/bin/find . -exec /bin/bash -p \; -quit
root@abyss:/home/captain# ls -laR
.:
total 24
drwx------ 3 captain captain 4096 Nov 10 14:28 .
drwxr-xr-x 1 root    root    4096 Nov 10 14:28 ..
-rw-r--r-- 1 captain captain  220 Mar 27  2022 .bash_logout
-rw-r--r-- 1 captain captain 3526 Mar 27  2022 .bashrc
-rw-r--r-- 1 captain captain  807 Mar 27  2022 .profile
drwx------ 2 captain captain 4096 Nov 10 14:28 .ssh

./.ssh:
total 20
drwx------ 2 captain captain 4096 Nov 10 14:28 .
drwx------ 3 captain captain 4096 Nov 10 14:28 ..
-rw-r--r-- 1 captain captain  395 Nov 10 14:28 authorized_keys
-rw------- 1 captain captain 1823 Nov 10 14:28 id_rsa
-rw-r--r-- 1 captain captain  395 Nov 10 14:28 id_rsa.pub
root@abyss:/home/captain# cd /root/
root@abyss:~# ls -laR
.:
total 20
drwx------ 1 root root 4096 Nov 10 14:28 .
drwxr-xr-x 1 root root 4096 Nov 10 14:28 ..
-rw-r--r-- 1 root root  571 Apr 10  2021 .bashrc
-rw-r--r-- 1 root root  161 Jul  9  2019 .profile
-r-------- 1 root root   32 Nov 10 14:28 flag.txt
root@abyss:~# cat flag.txt
ABYSS{d33p_s3cr3ts_r3v3al3d_99}
root@abyss:~#
```

Figura 12. Abuso de find (GTFOBins) para obtener una shell root y lectura de /root/flag.txt.

Compromiso completo

El panel del laboratorio valida la flag de root, confirmando el compromiso total de ABYSS.



Figura 13. Panel de whoami-labs: laboratorio Abyss comprometido y flag de root validada.

4. Hallazgos detallados

Severidad según CVSS 3.1. CWE = Common Weakness Enumeration · OWASP Top 10 2021 · técnicas MITRE ATT&CK.

V-01 Redis expuesto en red sin autenticación y credenciales en texto claro

Crítica

CVSS 3.1	**9.8** `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`
CWE	CWE-306 · CWE-312
OWASP	A05:2021 – Security Misconfiguration · A07:2021 – Authentication Failures
MITRE ATT&CK	T1190 · T1552.001

DESCRIPCIÓN

El servicio Redis 6.0.16 está accesible desde la red en el puerto 6379/tcp sin ningún mecanismo de autenticación (sin `requirepass` ni ACLs). Además, almacena una credencial de usuario en texto claro en la clave `user:scuba:password`. Cualquier atacante con conectividad de red puede leer (y escribir) datos arbitrarios y recuperar directamente las credenciales de acceso al sistema.

IMPACTO

Compromiso directo de credenciales válidas que habilita el acceso inicial por SSH. Redis sin autenticación permite además escritura arbitraria, vía habitual de RCE.

REMEDIACIÓN

- Habilitar autenticación (`requirepass` con secreto de alta entropía) y, a ser posible, ACLs por usuario.
- Vincular Redis a `127.0.0.1` / red interna y bloquearlo con firewall; nunca exponerlo a redes no confiables.
- No almacenar contraseñas en claro: usar un gestor de secretos y, para verificación, hashes con sal (argon2/bcrypt).
- Activar `protected-mode` y rotar de inmediato la credencial expuesta.

V-02 Clave privada SSH protegida con contraseña débil y ubicada en zona accesible — Alta

CVSS 3.1	**8.1** `AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:N/A:N`
CWE	CWE-522 · CWE-326 · CWE-521
OWASP	A04:2021 – Insecure Design · A07:2021
MITRE ATT&CK	T1552.001 · T1110.002

DESCRIPCIÓN

En el home de `scuba` se encuentra `captain_key.zip`, un ZIP cifrado que contiene la clave privada SSH (`id_rsa`) del usuario `captain`. La contraseña del ZIP es trivial (`ocean`, presente en `rockyou.txt`) y se recupera en segundos con un ataque de diccionario offline. La propia clave privada, material altamente sensible, no debería ser accesible por otros usuarios.

IMPACTO

Movimiento lateral de `scuba` a `captain`, usuario con la vía directa de escalada a root.

REMEDIACIÓN

- No distribuir claves privadas por el sistema de ficheros; cada clave debe residir solo en el `~/.ssh` de su propietario con permisos 600.
- Si una clave debe cifrarse, usar una passphrase larga y aleatoria (no palabras de diccionario).
- Rotar/revocar la clave `id_rsa` expuesta y la correspondiente entrada en `authorized_keys`.
- Preferir autenticación por certificados SSH de vida corta frente a claves estáticas.

V-03 Escalada de privilegios: sudo NOPASSWD sobre /usr/bin/find — Alta

CVSS 3.1	**7.8** `AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H`
CWE	CWE-250 · CWE-269
OWASP	A04:2021 – Insecure Design
MITRE ATT&CK	T1548.003

DESCRIPCIÓN

El usuario `captain` puede ejecutar `/usr/bin/find` como root sin contraseña (`(ALL) NOPASSWD: /usr/bin/find`). `find` admite `-exec`, por lo que (técnica documentada en GTFOBins) permite lanzar una shell privilegiada: `sudo /usr/bin/find . -exec /bin/bash -p \; -quit`.

IMPACTO

Control total del host como root (`uid=0`) y lectura de la flag en `/root/flag.txt`.

REMEDIACIÓN

- Retirar la regla `NOPASSWD` sobre `find` del fichero sudoers.
- Nunca otorgar por sudo binarios con capacidad de ejecutar comandos (`find`, `vim`, `awk`, `python`, intérpretes…).
- Aplicar mínimo privilegio y auditar `/etc/sudoers` y `/etc/sudoers.d/` contra una línea base.
- Monitorizar el uso de `sudo` y de GTFOBins conocidos.

V-04 Divulgación de información por ficheros de desarrollo y listado de directorios — Media

CVSS 3.1	**5.3** `AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`
CWE	CWE-200 · CWE-548
OWASP	A05:2021 – Security Misconfiguration
MITRE ATT&CK	T1083 · T1589

DESCRIPCIÓN

El servidor web expone el directorio `/dev/` con el listado de contenidos activado y un fichero `changelog.txt` con notas internas. La nota «Created temporary scuba user for testing» revela un nombre de usuario válido del sistema, reduciendo drásticamente el esfuerzo del atacante en las fases posteriores.

IMPACTO

Enumeración de usuarios y rutas internas; facilita y acelera el acceso inicial.

REMEDIACIÓN

- Desactivar el listado de directorios de Apache (`Options -Indexes`).
- Retirar ficheros de desarrollo/notas (`changelog.txt` , backups) del árbol web público.
- No incluir nombres de usuario, rutas ni secretos en artefactos accesibles públicamente.
- Revisar el despliegue para que solo se publique el contenido estrictamente necesario.

V-05 Transporte sin cifrar y divulgación de versiones de servicio — Baja

CVSS 3.1	**3.7** `AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N`
CWE	CWE-319 · CWE-200
OWASP	A05:2021 – Security Misconfiguration
MITRE ATT&CK	T1040

DESCRIPCIÓN

El servicio web opera en HTTP sin TLS y los banners de servicio divulgan versiones concretas (Apache 2.4.67, OpenSSH 8.4p1, Redis 6.0.16), lo que permite correlacionar vulnerabilidades conocidas y expone el tráfico a interceptación.

IMPACTO

Captura de credenciales/sesiones en tránsito y mapeo de superficie de ataque por versiones.

REMEDIACIÓN

- Forzar HTTPS/TLS y HSTS; redirigir todo el tráfico HTTP a HTTPS.
- Ocultar o minimizar los banners de versión (`ServerTokens Prod` , `ServerSignature Off`).
- Mantener los servicios actualizados dentro de un proceso de gestión de parches.

5. Plan de remediación priorizado

Prioridad	Acción	Hallazgo

1	Proteger Redis (autenticación + binding local + firewall) y eliminar credenciales en claro; rotar la contraseña de `scuba`.	V-01
2	Retirar la regla `sudo NOPASSWD` sobre `find`; aplicar mínimo privilegio en sudoers.	V-03
3	Eliminar la clave privada del sistema de ficheros, revocarla/rotarla y usar passphrases fuertes.	V-02
4	Desactivar el listado de directorios y retirar ficheros de desarrollo del árbol web.	V-04
5	Forzar HTTPS/TLS y ocultar banners de versión.	V-05

6. Conclusión

ABYSS demuestra cómo varias debilidades individualmente modestas se **encadenan** hasta el compromiso total. El error raíz no es un fallo de software exótico, sino **configuración y gestión de secretos deficientes**: un servicio de datos sin autenticación, contraseñas débiles y reutilizadas, una clave privada al alcance de otro usuario y permisos `sudo` excesivos.

> **Lección:** aplicar correctamente *un solo* principio habría roto la cadena. Sin el Redis abierto no hay acceso inicial; con una passphrase fuerte no se obtiene la clave de `captain`; y sin el `sudo NOPASSWD` sobre `find` no hay escalada a root. **Defensa en profundidad** y **mínimo privilegio** son las contramedidas clave.

Documento confidencial. Elaborado por **Josep Sanz** en el marco de las prácticas de ciberseguridad (laboratorio autorizado whoami-labs). Las credenciales y la flag incluidas pertenecen al entorno de laboratorio y carecen de validez fuera de él.